

LAB 7

FILE ANALYSIS - SCANNING RESULT

Subject: Vulnerability Analysis

Name: Haikal Danial Bin Hazrul

ID: 52215125778

Question 1: Analyse packet1.pcap and find the flag.

U1VDVEYyMDIze2FpX2lzX2Nvb2x9 = SUCTF2023{ai_is_cool}

Question 2: Analyse packet2.pcap and find the flag.

(No flag provided in document)

Question 3: Interpret an Nmap Output

Nmap Scan Results

PORT	STATE	SERVICE	VERSION
21/tcp	open	ftp	vsftpd 2.3.4
22/tcp	open	ssh	OpenSSH 5.3p1
80/tcp	open	http	Apache 2.2.8
139/tcp	open	netbios-ssn	
445/tcp	open	microsoft-ds	Windows 7 Professional 7601 SP1

1. Attacker Capabilities

PORT	SERVICE	ATTACKER CAPABILITIES
21/tcp	FTP (vsftpd 2.3.4)	Brute-force credentials; Exploit known backdoor to gain remote root shell.
22/tcp	SSH (OpenSSH 5.3p1)	Brute-force user passwords; Use outdated crypto to downgrade or intercept sessions.
80/tcp	HTTP (Apache 2.2.8)	Enumerate web directories and files.

PORT	SERVICE	ATTACKER CAPABILITIES
139/445/tcp	SMB (Windows 7 SP1)	Perform pass-the-hash, SMB relay, or brute-force attacks.

2. Known Vulnerabilities

SERVICE	VERSION	KNOWN VULNERABILITIES
vsftpd	2.3.4	Backdoor (CVE-2011-2523): Sending a smiley face :) as username gives unauthenticated root shell on port 6200. Also DoS and directory traversal.
OpenSSH	5.3p1	User enumeration (CVE-2016-6210, CVE-2018-15473); Weak key exchange algorithms; CVE-2010-4478 (potential remote crash).
Apache	2.2.8	Multiple DoS (CVE-2008-0005, CVE-2011-3192); Directory traversal (CVE-2008-2938).
SMB	Windows 7 SP1	EternalBlue (MS17-010): Remote code execution via SMBv1; Numerous privilege escalation and info disclosure CVEs.

3. Highest Risk Analysis

Highest Risk: Port 21 (vsftpd 2.3.4 backdoor)

Reason: Immediate, unauthenticated root shell. The backdoor requires no credentials. An attacker simply connects to FTP, sends USER :), then connects to port 6200 to get a root shell.

4. Attack Path

- **Step 1:** Get root shell via FTP backdoor.

5. Remediation

Service	Action
vsftpd 2.3.4	Upgrade to vsftpd $\geq$ 2.3.5 (or latest stable).
General	If not needed, disable FTP and use SFTP/SCP instead. Ensure FTP is firewalled to only trusted IPs.

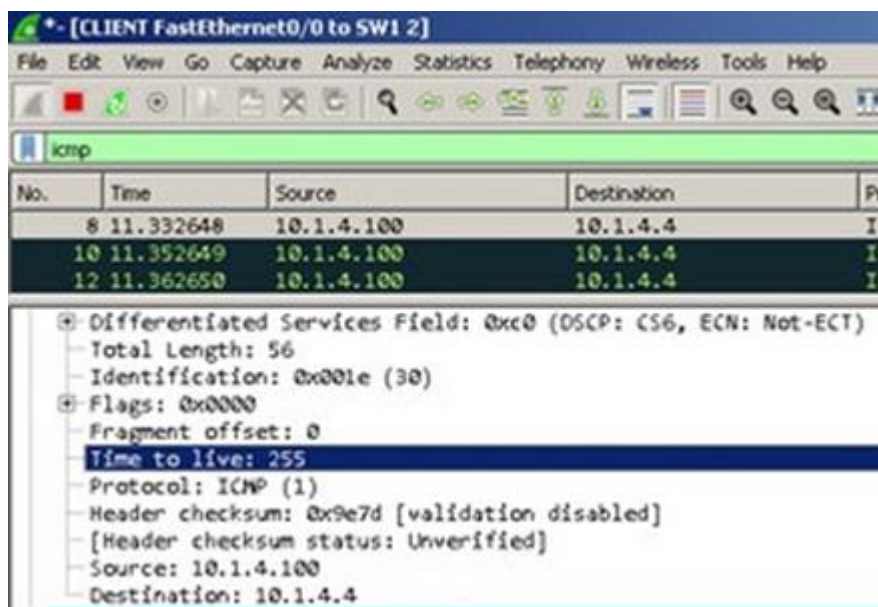
Question 4: Identify the OS (OS Fingerprinting) - TTL

```
[sk@ostechnix ~]$ ping -c5 localhost
PING localhost(localhost (:::1)) 56 data bytes
64 bytes from localhost (:::1): icmp_seq=1 ttl=64 time=0.063 ms
64 bytes from localhost (:::1): icmp_seq=2 ttl=64 time=0.057 ms
64 bytes from localhost (:::1): icmp_seq=3 ttl=64 time=0.070 ms
64 bytes from localhost (:::1): icmp_seq=4 ttl=64 time=0.067 ms
64 bytes from localhost (:::1): icmp_seq=5 ttl=64 time=0.056 ms

--- localhost ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4096ms
rtt min/avg/max/mdev = 0.056/0.062/0.070/0.005 ms
```

• : ttl=64

Answer: Linux / FreeBSD / macOS



• : Time to live: 255

Answer: Solaris / Cisco / Network devices

```
64 bytes from 192.168.122.239: icmp_seq=1 ttl=128 time=6.85 ms
64 bytes from 192.168.122.239: icmp_seq=2 ttl=128 time=0.510 ms
64 bytes from 192.168.122.239: icmp_seq=3 ttl=128 time=0.601 ms
64 bytes from 192.168.122.239: icmp_seq=4 ttl=128 time=0.541 ms
64 bytes from 192.168.122.239: icmp_seq=5 ttl=128 time=0.558 ms
```

• : ttl=128

Answer: Windows

Question 5: Analyse the Nessus file (Ghostcat)

1. **Affected Port Number:** 8009
2. **Affected Protocol:** AJP
3. **CVSS Score:** 9.8
4. **Exploit Availability: Exploit-DB:** The vulnerability is indexed on Exploit-DB, providing downloadable code that demonstrates how the Arbitrary File Read/Inclusion works.
5. **CVE:** CVE-2020-1938